HOOKLIGHT

PREGUNTAS
PHISHING

Preguntas Evaluativas

En este documento se pretende responder de forma resumida las preguntas evaluativas del Proyecto 2 (Phishing)

Presentado por:

Francisco Mestre

INDICE

2.INTRODUCCIÓN AL PHISHING

- ***1.2***.*¿Qué son los correos electrónicos falsos?*
- ***1.3***.*Personalización de phishing a través de la Inteligencia Artificial*
- ***1.4***.*¿Qué datos desean obtener?*

3.¿CUÁLES SON LOS PRINCIPIOS PSICOLÓGICOS QUE HACEN EFECTIVO EL PHISHING?

- **4.1.***introducción*
- ***4.2***.*técnicas psicológicas*
- ***5.1***.*Características de Individuos*
- **5.2**.Grupos
- **5.3**.Placebo e información real
- ***TECNICAS DE PERSUASION:***
- ***7.1.A.***Principios de persuasión
- **7.2**.**B**.Reciprocidad
- **7.3**.**C**.Escasez
- **7.4.D**.Autoridad

8.DIFERENCIAS ENTRE SPEAR Y WHALING PHISHING

- **9.1.**SPEAR PHISHING
- **9.2.**WHALING PHISHING

10.CONSIDERACIONES LEGALES AL REALIZAR SIMULACIONES DE PHISHING

- **11.1.***el reglamento general de Protección de datos.*
- ***11.2.****Argentina - Ley 25.326.*

-***CONSIDERACIONES LEGALES***

- ***12.1.A.****Comunicación antes y despues.*
- ***12.1.B.****Recopilación de datos.*
- ***12.1.C.****Recomendaciones en Señuelos.*
- ***13.1.D.****Creación de evidencias.*
- ***13.2.E.****Ejemplo Formulario.*

14. LA PÁGINA EDUCATIVA POST-PHISHING

- **15.**La página post-phishing.

16.DEFENSA Y PROTECCIÓN CONTRA PHISHING SOFISTICADOS

- **17.1.***Phishing sofisticado***.**
- ***17.2.****Tecnologias modernas***.**
- ***18.Tipos Ataques de Phishing sofisticados-***
- ***19.Como Indentificarlo.***
- ***20.Técnicas de prevención.***
- ***21.Conclusión.***

INTRODUCCIÓN AL PHISHING

La palabra **phishing** quiere decir suplantación de identidad.
Es una técnica de **ingeniería social** que usan los ciberdelincuentes para obtener información confidencial de los usuarios de forma fraudulenta y así apropiarse de la identidad de esas personas.

Los ciberdelincuentes envían correos electrónicos falsos como anzuelo para "pescar" contraseñas y datos personales valiosos.

¿Qué son los correos electrónicos falsos?

Son correos electrónicos que contienen información falsa y enlaces que redirigen tus respuestas hacia páginas de internet falsas con formularios y preguntas para obtener tus datos personales.

Personalización de phishing a través de la Inteligencia Artificial:

La inteligencia artificial (IA) ha influido significativamente en el phishing, tanto en el perfeccionamiento de las técnicas utilizadas por los **ciberdelincuentes** como en las herramientas de defensa desarrolladas para combatirlo.
La IA permite automatizar el proceso de creación de mensajes y generar ataques másivos con mayor facilidad, permite crear correos electrónicos altamente personalizados y dirigidos al entender los intereses y comportamientos de la víctima o correos que parezcan más auténticos y convincentes, difíciles de distinguir de los mensajes legítimos.

¿Qué datos desean obtener?

- datos de contraseñas
- números de tarjetas de crédito
- DNI
- CUIT o CUIL
- nombres de usuario
- códigos PIN

Una forma de verificar si fuiste víctima de una ataque de phishing es revisar en forma periódica tus resúmenes bancarios buscando transferencias que no autorizaste.

¿CUÁLES SON LOS PRINCIPIOS PSICOLÓGICOS QUE HACEN EFECTIVO EL PHISHING?

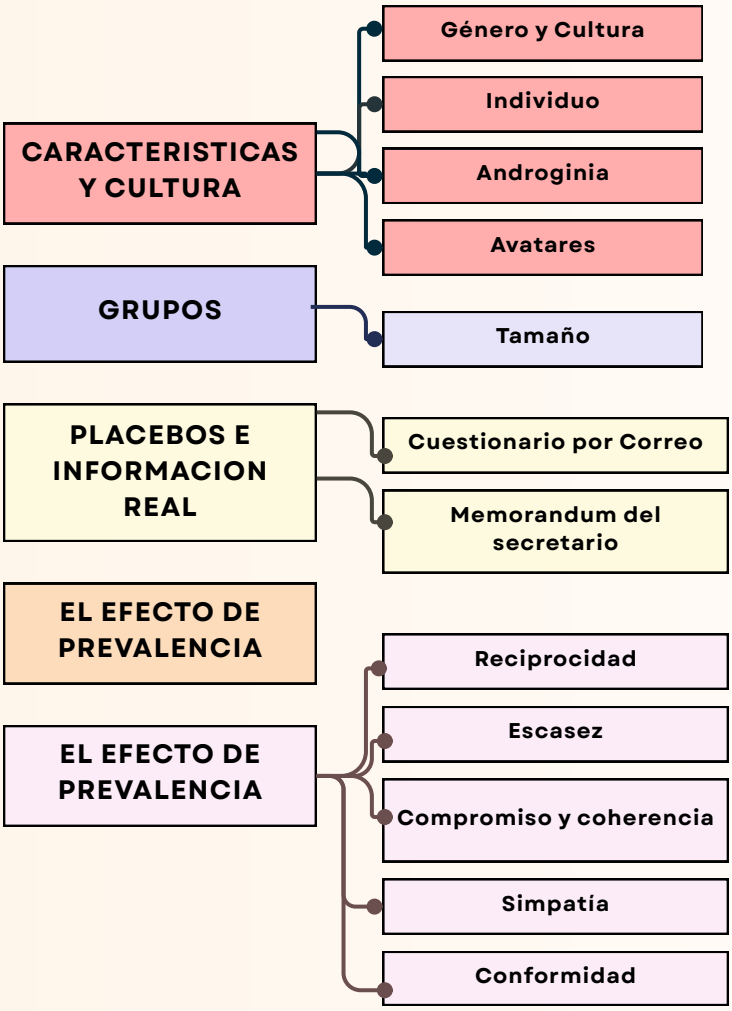
El **Phishing** en sí se vale de la psicología humana para manipular a las personas y conseguir que revelen información sensible o realicen acciones en contra de sus intereses. El Phishing hace uso de las técnicas psicológicas utilizadas en la **ingeniería social**, por ello es tan efectivo.

INTRODUCCIÓN

La era digital ha facilitado cada vez más a los delincuentes el acceso a grandes cantidades de información. Sin embargo, no es el gran volumen de información ni, con frecuencia, la dificultad de implementar contramedidas de seguridad lo que representa la mayor amenaza; sino la capacidad de manipular la percepción humana

La **ingeniería social** se dirige en gran medida a la mente inconsciente, con el objetivo de alterar la percepción de las víctimás y, en última instancia, manipular sus decisiones sin que se den cuenta.

TÉCNICAS PSICOLÓGICAS



TÉCNICAS PSICOLOGICAS I

Debido al enfoque que tenemos sobre el phishing nos encargaremos de explicar solo las técnicas de psicología usadas para este tipo de ciberdelitos. Es importante saber que existen más técnicas de ingeniería social ya que no siempre se utilizan las mismás tecnias.

Como podemos observar en la figura 1.

Tenemos 5 Grupos de técnicas.

- Caracteristicas
- Grupos
- Placebos
- Prevalencia
- El Efecto Prevalencia.

Los más empleados son el de **Cultura** y **Placebos**.

TÉCNICAS

CARACTERISTICAS DE INDIVIDUO Y CULTURA

Esta sección examina la influencia del género, la cultura y las características individuales en la conformidad y la persuasión. . Este análisis busca destacar la compleja interacción entre los factores personales y sociales que configuran las respuestas conductuales e influyen en las técnicas de interacción humana . (Aquí se encuentra el **spear phishing**)

Las **características** de la persona persuadida afectan la tasa de éxito del mecanismo de persuasión y, a su vez, la eficacia de los ataques de ingeniería social. Las siguientes características individuales son importantes al persuadir a alguien:

- **Autoestima**: Una autoestima más baja crea una mayor necesidad de pertenencia, lo que a su vez aumenta la necesidad de aprobación, incrementando así la conformidad.

- **Edad**: Las personas menores de 40 años tienen mayor probabilidad de verse influenciadas.

- **Afiliación**: Las personas afiliadas al grupo que crea conformidad tienen más probabilidades de conformarse.

GRUPOS

Se ha observado que la interacción de las personas en entornos grupales afecta en gran medida su razonamiento. Las personas tienden a conformarse cuando se les impone la presión de la opinión de un grupo

PLACEBO E INFORMACION REAL

Dentro de esta categoría se encuentra el phishing masivo o tradicional , se encuentra tanto el **Spear Phishing** y el **whaling**. Se de muestra que muchos usuarios completan formularios sin saber su origen , otorgando datos que son recolectados para un phishing más focalizado

Las personas tienden a obedecer más cuando se enfrentan a una solicitud que a una exigencia. Es mucho más probable que cumplan con una solicitud que se ajuste a las condiciones habituales de sus acciones. Un delincuente puede maximizar la efectividad de un ataque de ingeniería social estudiando las condiciones de la víctima para planificar el ataque en consecuencia, utilizando el estilo de solicitud adecuado. Mediante un mensaje de alguien haciéndose pasar por tu jefe o algún ceo.

TÉCNICAS DE PERSUASIÓN

El efecto de prevalencia es el fenómeno psicológico que dificulta la detección de señales poco frecuentes, incluso considerando su probabilidad significativamente baja de ocurrencia.

Se realizó un experimento para demostrar cómo se puede aplicar el efecto de prevalencia a la ingeniería social, en particular al phishing. Los participantes recibieron correos electrónicos durante un periodo específico, solicitándoles que descargaran un archivo PDF o cargaran uno existente. Tras leer un correo electrónico en su bandeja de entrada, los participantes del estudio podían realizar una de las siguientes tres acciones:

- *Descargar archivos adjuntos.*
- *Responder y subir sus propios archivos adjuntos*
- *Reportar dicho mensaje como posiblemente malicioso*

La naturaleza de los correos electrónicos era una de las siguientes:

- **Legítimo**: Enviado desde direcciones de correo electrónico bajo un dominio específico que termina en ".com".
- **Malware** : el archivo adjunto sería un archivo ejecutable (.exe) en lugar de un archivo .pdf.
- **Phishing**: el correo electrónico tendría una dirección de remitente con el dominio de nivel superior ".tv".

PRINCIPIOS DE PERSUASIÓN

Los principios de persuasión son propiedades del infractor que pueden influir en el comportamiento de la víctima, aumentando las probabilidades de sumisión a su favor los principios son los siguientes

- **reciprocidad**
- **escasez**
- **autoridad**
- **compromiso** y **consistencia**

RECIPROCIDAD

La técnica de la reciprocidad implica que el agresor ofrece algo a cambio. Esto lo coloca en una posición ventajosa, ya que la víctima se siente en deuda con el solicitante por su gesto, aunque el regalo real sea insignificante. Esto le permite hacer ataques de bienes.

ESCASEZ

a técnica de escasez se implementa cuando el agresor convence al individuo de que el producto o servicio ofrecido tiene una disponibilidad limitada. La víctima tiende a sobreestimar el valor de dicho servicio o producto y tiene una mayor probabilidad de acceder al plan del agresor. Por ejemplo decirte que tu cuenta de Microsoft está a punto de vencer y te pide que pongas tus datos bancarios para renovar

AUTORIDAD

La probabilidad de que una víctima acceda a una solicitud es mayor cuando esta proviene de una figura autoritaria . Por ejemplo un mensaje de tu jefe o ceo de la empresa.

¿CÓMO SE DIFERENCIA EL PHISHING DEL SPEAR PHISHING Y DEL WHALING?

- el **spear phishing** es un ataque dirigido y personalizado hacia individuos o grupos específicos dentro de una organización.

- El **whaling** es una forma avanzada de spear phishing, dirigida exclusivamente a altos ejecutivos ("ballenas")

SPEAR PHISHING

El phishing selectivo , como su nombre indica, se refiere a un método de phishing dirigido deliberadamente a tipos específicos de usuarios.
En el phishing selectivo, los cibercriminales limitan sus ataques a individuos o grupos específicos, como el personal de una empresa.Para aumentar la credibilidad del cebo, los cibercriminales se aseguran de que el lenguaje, el tono, la fuente y la justificación/llamada a la acción del mensaje de phishing estén adaptados para captar la atención o ser muy relevantes para el grupo específico de destinatarios.

EJEMPLO
Un correo electrónico de phishing dirigido al departamento de finanzas de una empresa tendría mensajes que incluyen referencias a procesos financieros comunes, utiliza jerga o terminología conocida por los profesionales y el personal de finanzas y supuestamente proviene de una fuente que interactúa regularmente con el departamento, como proveedores, proveedores de aplicaciones empresariales, clientes que exigen reembolsos, auditores fiscales y especialistas en adquisiciones.

WHALING PHISHING

El whaling profundiza aún más en el concepto de phishing selectivo al dirigirse a un grupo más reducido de personas: ejecutivos de alto nivel con acceso de superusuario a muchos de los sistemás de su organización, así como la autoridad para tomar decisiones importantes y realizar transacciones financieras. Considerados los pesos pesados de la jerarquía o el organigrama de una empresa, estos son los "peces gordos" que buscan los ciberdelincuentes, principalmente con el fin de extraer sus poderosas credenciales de usuario u otra información confidencial

¿Por qué centrarse en los altos mandos de una empresa? Sencillo. En comparación con la captura de peces pequeños, la recompensa para las ballenas es mucho mayor si el intento tiene éxito. Por lo tanto, los actores de amenazas invierten más tiempo y esfuerzo en perfeccionar sus tácticas y hacer que sus comunicaciones parezcan muy legítimás, dado que se supone que la mayoría de estos pesos pesados son inteligentes, perspicaces o bien formados.

QUÉ CONSIDERACIONES LEGALES EXISTEN AL REALIZAR SIMULACIONES DE PHISHING ?

La clave no es evitar estas pruebas cruciales, sino ejecutarlas bajo un marco robusto que equilibre la necesidad de resiliencia empresarial con el estricto cumplimiento de la **RGPD( )**

EL REGLAMENTO GENERAL DE PROTECCIÓN DE DATOS

Para ejecutar una simulación de phishing de forma legal bajo la **RGPD *(Reglamento General de Protección de Datos)* ,** en ciberseguridad es la normativa estricta de la UE, vigente desde 2018, que obliga a organizaciones a proteger los datos personales de ciudadanos.

la base jurídica correcta es el "interés legítimo" de la empresa, no el consentimiento del empleado. Solicitar el consentimiento previo anularía la eficacia de la prueba, mientras que el interés legítimo proporciona una base firme y defendible para proteger los activos críticos de la organización, siempre que se documente adecuadamente a través de un Test de Ponderación. El consentimiento bajo la **RGPD** debe ser libre e informado. Si informás a tus empleados de que van a recibir un correo de phishing simulado en una fecha concreta, la prueba pierde todo su valor. Dejaría de ser una medida realista de la vulnerabilidad para convertirse en un mero ejercicio teórico.

ARGENTINA - LEY 25.326

La Ley Argentina (**25.326**) de protección de datos personales regula la protección de la información personal almacenada en archivos, registros, bancos de datos y otros espacios similares, sean públicos o privados, a fin de garantizar el derecho al honor, a la intimidad y a la información. Por tanto, es una norma proteccionista, con un ámbito y objetivos que, de base, nos recuerdan mucho a los regulados en el RGPD.

La Ley 25.326 parte de la base de que, para que un tratamiento de datos sea lícito, su titular ha de haber otorgado su consentimiento, de forma libre, expresa e informada. No obstante, también se podrán tratar datos sin consentimiento cuando:

- La información provenga de fuentes de acceso público
- Sea necesario para el cumplimiento de obligaciones legales
- Deriven de una relación contractual, científica o profesional
- Deban ser tratados por entidades financieras, respecto de sus clientes
- Consten en listados relativos exclusivamente a nombre, documento nacional de identidad, identificación tributaria, fecha de nacimiento y domicilio

CONSIDERACIONES LEGALES

1.COMUNICACION Y TRANSPARENCIA (ANTES Y DESPUES)

La confianza es el fundamento de una seguridad positiva. Una comunicación opaca o inexistente puede generar rechazo y conflictos laborales innecesarios.

- **Antes de la campaña**: Es crucial informar a los empleados de forma general. No se trata de revelar las fechas o los señuelos específicos **(lo que anularía el test)**, sino de comunicar la existencia de un programa continuo de formación y evaluación de la ciberseguridad que incluye simulaciones prácticas. Debe ser informado en la institución o compañía

- **Después de la campaña**: La comunicación de resultados es igual de importante. Estos deben presentarse siempre de forma agregada y anónima. El objetivo es destacar las áreas de mejora colectivas y celebrar los éxitos (como un alto porcentaje de reportes de phishing), nunca señalar o avergonzar a individuos. El enfoque debe ser pedagógico, no punitivo.

2.RECOPILACIÓN DE DATOS

El principio de minimización de datos de la RGPD es tu mejor guía. Acorde a la RGPD, solo debes recopilar la información estrictamente necesaria para cumplir la finalidad de la simulación de phishing declarada en tu LIA. Procura solo recopilar datos que impacten en las métricas . **No Recopiles información confidencial ni personal! .**

3.CONSIDERACIONES EN SEÑUELOS

No todos los señuelos son válidos en una simulación de phishing desde una perspectiva legal. Utilizar temáticas que puedan causar una angustia desproporcionada o que afecten a la dignidad del trabajador es la forma más rápida de invalidar tu interés legítimo y enfrentarte a problemás legales.

- **Temás laborales sensibles**: Falsos comunicados sobre despidos, cambios en la nómina o bonificaciones extraordinarias.

- **Salud personal o familiar**: Comunicaciones falsas sobre resultados médicos, citas, seguros de salud o accidentes.

4.CREACIÓN DE EVIDENCIAS

- Finalmente, debes ser capaz de demostrar tu diligencia debida. Tu programa de simulación de phishing debe estar respaldado por un sólido dossier de cumplimiento legal y normativo. Este es tu principal activo en caso de una auditoría interna o una inspección por parte de una autoridad como el gobierno Argentino o la Agencia Española de Protección de Datos

SIMULACIÓN ACADÉMICA DE PHISHING

PROYECTO: SIMULACIÓN AUTOMATIZADA CON N8N
INSTITUCIÓN: HOOKLIGHT
RESPONSABLE: HOOKLIGHT
CONTACTO: +54 2613075498
PERÍODO ACADÉMICO: UTN-MENDOZA

Declaro que he sido informado/a sobre la realización de una simulación controlada de phishing con fines exclusivamente educativos y de concientización en ciberseguridad.

1. FINALIDAD

El objetivo es medir métricas de interacción (apertura, clic y reporte) y brindar micro-capacitaciones inmediatas para fortalecer la conciencia en seguridad informática.

2. MODALIDAD

- Podré recibir correos electrónicos simulados dentro del período académico indicado.
- No se informará la fecha exacta de envío para preservar la validez pedagógica.
- No se solicitarán contraseñas reales ni datos sensibles.

3. DATOS QUE PODRÁN REGISTRARSE

- Su correo que será Cifrado.
- Tipo de evento (open, click o report).
- Fecha y hora del evento.
- Los datos serán utilizados únicamente con fines académicos y estadísticos.

4. CONFIDENCIALIDAD Y RETENCIÓN

Los datos serán conservados por un máximo de 30 días posteriores al cierre de la campaña, luego serán eliminados o anonimizados.

5. VOLUNTARIEDAD

Mi participación es voluntaria.
Puedo retirar mi consentimiento y solicitar la eliminación de mis datos en cualquier momento sin consecuencias. Declaro haber leído y acepto participar.

NOMBRE Y APELLIDO: _____
DNI: _____

POR QUÉ ES IMPORTANTE LA PÁGINA EDUCATIVA POST-PHISHING

PAGINA POST PHISHING

- La página educativa post-phishing es fundamental porque transforma un error de seguridad en una experiencia de aprendizaje inmediata. Refuerza la concienciación al mostrar al usuario qué señales pasó por alto, reduce drásticamente el riesgo de futuros incidentes y convierte a los empleados o estudiantes en una línea de defensa activa contra ciberataques.

HOOKLIGHT

Simulación de Phishing

⚠️ Has interactuado con un correo simulado como parte de una campaña de concientización.

Este ejercicio forma parte del programa educativo de **Hooklight** para fortalecer la cultura de ciberseguridad.

¿Qué señales podrías haber detectado?

- Remitente ligeramente alterado o sospechoso.
- Urgencia injustificada.
- Enlaces que no coinciden con el dominio oficial.
- Solicitud inesperada de información o acción inmediata.

Buenas prácticas:

- Verificar siempre el dominio del remitente.
- Pasar el cursor sobre los enlaces antes de hacer clic.
- No ingresar credenciales desde enlaces recibidos por correo.
- Reportar correos sospechosos al equipo de seguridad.

Recuerda: el objetivo no es sancionar, sino aprender y fortalecer nuestra postura de seguridad.

Entendido

Proyecto académico de simulación automatizada de phishing
Hooklight © 2026

CÓMO PROTEGERÍAS UNA ORGANIZACIÓN CONTRA ATAQUES DE PHISHING SOFISTICADOS

PHISHING AVANZADO Y DEFENSA

Los ataques de **phishing avanzado** son precisos y difíciles de detectar, ya que parecen mensajes auténticos a simple vista por su gran parecido con las comunicaciones de la empresa o web suplantada. **Utilizan técnicas de ingeniería social** para conseguir tus contraseñas, el acceso a tu cuenta del banco o instalar malware en tu ordenador. Aprovechan información real sobre ti que han obtenido de diversas formás, como filtraciones en las que tus datos aparecen o investigando en redes sociales.

Es bastante probable que si recibes un ataque de phishing avanzado el **cibercriminal** ya posea información sobre ti y la aproveche para incrementar la credibilidad del mensaje. Puede ser el **nombre completo**, un **número de teléfono**, **una dirección** o incluso información más privada como el **DNI**. Esta información suele ser conseguida en bases de datos de filtraciones que se venden en foros y páginas de la dark web.

TECNOLOGIAS MODERNAS

Los atacantes utilizan tecnologías y plataformás modernas para mejorar la efectividad de sus campañas de phishing:

- **Phishing as a Service (PhaaS):** Plataformás en la dark web que ofrecen servicios de phishing completos, desde la creación de correos electrónicos basados en plantillas hasta el envío másivo de los correos.

- **Herramientas avanzadas de Phishing:** como ***GoPhish***, utilizado para realizar campañas másivas de phishing; o ***Evilginx***, que implementa tecnologías para realizar bypass de la autenticación multifactor.

ATAQUES DE PHISHING SOFISTICADO

SPEAR PHISHING

- utiliza información detallada sobre la víctima para ganar credibilidad. La información puede ser recogida a través de fuentes abiertas (OSINT) o en fugas de datos de empresas que hayan sufrido un ciberataque, por ejemplo. común en entornos empresariales

WHALING

- Apunta a altos ejecutivos y personas con puestos importantes en las empresas. Debido al perfil de las víctimás, los correos suelen ser extremadamente elaborados. El Atacante ya investigo a la víctima

PHISHING A TRAVÉS DE REDES SOCIALES

A través de las redes sociales, los cibercriminales pueden contactar con usuarios de diferentes servicios. Entre las técnicas más comunes destacan:

- **Suplantación de marca**: Los atacantes crean perfiles falsos que simulan ser cuentas oficiales de empresas para engañar a los usuarios.

- **Suplantación de familiares**: A través de redes sociales los ciberdelincuentes fingen ser amigos de la infancia o familiares lejanos de la víctima, solicitando ayuda económica con urgencia. Estas estrategias explotan la confianza de los humanos con las relaciones cercanas.

ATAQUES EN TIEMPO REAL:

- Este tipo de ataques combina el phishing con interacciones en directo, como llamadas telefónicas o mensajes instantáneos. Los cibercriminales pueden simular ser trabajadores de entidades confiables (como bancos, empresas proveedoras de servicios o instituciones gubernamentales) utilizando datos específicos de la víctima para parecer legítimos.

- Por ejemplo, un estafador puede llamar alegando ser de un banco, contactando acerca de una falsa transacción que ha sido calificada como fraudulenta en la cuenta de la víctima, y pedir datos de acceso para “resolver el problema” urgentemente. Esto genera presión en la víctima, forzando a que se disminuya su tiempo de reacción y aumentando la probabilidad de éxito.

COMO RECONOCERLO

A continuación, conocerás las señales clave para evitar ser víctima de phishing:

ERRORES SUTILES EN EL LENGUAJE

Una de las señales más comunes de que estamos ante un ataque de phishing son los errores sutiles en el lenguaje. Pueden pasar desapercibidos si no se presta atención al mensaje, encontrar frases mal estructuradas o traducciones incorrectas debido a traducciones automáticas, que rompen el ritmo del mensaje.

URLS SOSPECHOSAS

No debemos interactuar con páginas que no conocemos o no estamos registrados dado que es probable que se trate de correo no deseado o un ataque phishing.
Puede que el atacante haya creado una web con un nombre de dominio similar, por lo que hay que ir con cuidado con las URL adjuntas en los correos. Si el correo dice ser de una aplicación o web es indispensable comprobar que las URL que se incluyen en el correo son las de la página oficial. Si detectas que el dominio es diferente, puede que estés siendo víctima de un ataque de phishing.

SOLICITUDES URGENTES O INUSUALES

Otra señal de alerta son los mensajes inusuales o que indican una gran urgencia. Los ciberdelincuentes buscan generar presión para que la víctima no piense con claridad y aumenten las probabilidades de sufrir el ataque de phishing.
Si se recibe una solicitud urgente inesperada, como un bloqueo inminente de una cuenta o una transacción sospechosa de un precio elevado, puede que se trate de un phishing. En escenarios de urgencia hay que utilizar los canales oficiales.

ARCHIVOS ADJUNTOS Y ENLACES DESCONOCIDOS

Antes de descargar un archivo, fíjate siempre en las extensiones de los archivos para verificar que el documento coincide con la extensión, ya que los atacantes suelen disfrazar los virus con extensiones que aparentan ser inofensivas. Los atacantes pueden intentar hacer pasar archivos corrientes como PDF en ejecutables con extensiones como ***".exe", ".msi", ".cmd", ".bat", ".lnk",*** entre otros.

TÉCNICAS DE PREVENCIÓN

VERIFICACIÓN DE IDENTIDAD:

- La verificación de identidad es una herramienta clave para la protección de los usuarios y empresas frente a ataques de phishing. Uno de los métodos más seguros y utilizados es el uso de biometría, como huellas dactilares, reconocimiento facial o escaneo de retina; garantizando un acceso difícil de falsificar.

ACTUALIZACIÓN CONSTANTE DE SOFTWARE:

- Tanto a nivel personal como empresarial, actualizar los sistemás operativos evita que los cibercriminales puedan aprovecharse de los fallos de seguridad para sus actividades fraudulentas. Es fundamental para evitar la explotación de las vulnerabilidades conocidas por los atacantes. Diferentes vulnerabilidades pueden ser aprovechadas por los actores maliciosos para atacar la infraestructura de tu empresa.

GESTIÓN SEGURA DE CONTRASEÑAS:

- Se recomienda utilizar contraseñas que contengan una combinación de letras, números y símbolos, con al menos 12 caracteres de longitud. Además, es recomendable que se cambien periódicamente en función de su criticidad, que puede variar entre tres y doce meses. Las cuentas con los accesos más críticos deben ser cambiadas con mayor frecuencia, y siempre junto a autenticación multifactor.

SIMULACIONES DE PHISHING

- Las simulaciones de phishing ayudan a educar a los empleados sobre cómo detectar intentos de fraude en tiempo real y medir la eficacia de las formaciones en ciberseguridad. Existen plataformás de formación que permiten crear campañas de phishing y establecer planes de formación para los usuarios que caigan en el anzuelo

- Para poner a prueba a los usuarios, un equipo de red team puede realizar una campaña de phishing ético para concienciar a los trabajadores de los peligros de no prestar atención e interactuar con correos maliciosos.

AUTENTICACIÓN MULTIFACTOR (MFA)

La autenticación multifactor (MFA) es un requisito indispensable para cualquier cuenta que sea creada. Esta capa de seguridad adicional frena a los cibercriminales en un escenario en el que consigan las credenciales o exploten una vulnerabilidad que les permita acceder a una cuenta, ya que será necesaria una confirmación adicional para realizar cualquier inicio de sesión.
Ya sea a través de mensajes SMS, correos electrónicos de verificación o aplicaciones de autenticación como Authenticator.

EDUCACIÓN Y CONCIENCIACIÓN

La formación continua es uno de los pilares de la protección ante phishing avanzado. Ofrecer formación periódica a través de cursos o capacitaciones. **Protejámonos contra la ciberdelincuencia y cuidémos entre todos divulgando más técnicas.**

CONCLUSION:

El phishing continúa evolucionando junto con las tecnologías digitales. Por ello, la combinación de educación, tecnología y cumplimiento normativo resulta esencial para fortalecer la resiliencia organizacional frente a amenazas cada vez más sofisticadas.

CONTACTO